

Guía metodológica de la Encuesta SQUARE

Uso, interpretación y cálculo de indicadores

Esta guía acompaña al modelo de encuesta SQUARE.

Su objetivo es que los números digan algo sensato y no solo adornen diapositivas.

1. Propósito de la encuesta

La encuesta SQUARE tiene tres propósitos principales:

1. Medir el grado de madurez en la ingeniería de requisitos de seguridad (inspirada en SQUARE) de organizaciones españolas, especialmente en sectores cubiertos por NIS2, ENS y normativa sectorial.
2. Generar indicadores comparables que permitan un análisis territorial (España frente a sí misma en el tiempo y frente a otros países o marcos de referencia).
3. Servir de espejo amable pero implacable para responsables de seguridad, tecnología y negocio, resaltando el valor estratégico de los requisitos de seguridad bien trabajados.

No pretende sustituir auditorías ni certificaciones, sino complementarlas con una mirada de ingeniería y calidad, enfocada en el proceso de definición y gestión de requisitos.

2. Población objetivo y roles

La encuesta está dirigida a organizaciones que:

- Operan servicios esenciales o importantes según NIS2.
- Forman parte de la Administración pública (AGE, CCAA, EELL) o sus proveedores IT/OT.
- Son organizaciones privadas con alta dependencia digital y voluntad de no estrellarse.

El rol ideal de respuesta combina:

- Conocimiento de la gestión de riesgos y seguridad (CISO o equivalente).
- Visibilidad sobre la ingeniería de sistemas y proyectos críticos.
- Capacidad de influir en procesos y decisiones.

Cuando sea posible, se recomienda que la encuesta se complete de forma colegiada (por ejemplo, una sesión conjunta de CISO, CIO, responsable de desarrollo y continuidad de negocio), para evitar respuestas “unipersonales” excesivamente optimistas o pesimistas.

3. Estructura de la encuesta y lógica SQUARE

La encuesta sigue, en espíritu, los nueve pasos de SQUARE, si bien agrupados en bloques:

4. Gobernanza y proceso SQUARE-like (P1.x)
5. Identificación de activos y riesgos (P2.x)
6. Cobertura y calidad de requisitos (P3.x)
7. Métricas e indicadores (P4.x)
8. Cumplimiento normativo y alineamiento (P5.x)
9. Continuidad y resiliencia (P6.x)
10. Tecnología y capacidades (P7.x)
11. Perspectiva económica: IGM y ROI (P8.x)
12. Cultura y autocrítica (P9.x)

Cada bloque permite inferir indicadores de madurez que, combinados, dan lugar a un Índice Global de Madurez (IGM) y a una lectura cualitativa sobre el retorno de invertir en requisitos de seguridad.

4. Escalas de respuesta y principios de codificación

Las respuestas cerradas (tipo lista) se codificarán en valores numéricos para facilitar el análisis. Se recomienda:

- Utilizar una escala de 0 a 4 (o 0 a 5 según el caso) donde 0 represente la ausencia de práctica y 4 el estado “ideal” razonable.
- Ser coherente en la dirección: valores altos deben representar mayor madurez o alineamiento.

Ejemplo de codificación para P3.1 (cobertura de requisitos):

- > 90 % → 4
- 70–90 % → 3
- 40–69 % → 2
- 10–39 % → 1
- < 10 % → 0
- No se sabe → nulo (se excluye del cálculo de media y se reporta como “dato desconocido”).

Los campos de texto libre (como P9.4) se pueden analizar cualitativamente (temas recurrentes, preocupaciones, etc.) sin traducirlos a métricas rígidas, salvo proyectos concretos que deseen desarrollar indicadores de cultura o percepción.

5. Cálculo del Índice Global de Madurez (IGM)

El IGM pretende sintetizar, en un único número entre 0 y 100, el estado de madurez de la organización en materia de requisitos de seguridad según el espíritu SQUARE.

5.1. Dimensiones principales

Se proponen cinco dimensiones:

13. Gobernanza del proceso de requisitos (GOV) – derivada de P1.x, P5.x.
14. Riesgos, activos y trazabilidad (RISK) – derivada de P2.x, P6.x.
15. Cobertura y calidad de requisitos (REQ) – derivada de P3.x.
16. Métricas y mejora continua (MET) – derivada de P4.x, P8.x.
17. Capacidades y cultura (CAP) – derivada de P7.x, P9.x.

Cada dimensión se calcula como media ponderada de las preguntas asociadas, tras codificación numérica. Las ponderaciones se pueden ajustar según el sector; por defecto, se sugiere peso igual para cada pregunta dentro de una dimensión.

5.2. Escalado

Cada dimensión se transforma a escala 0–100:

$$\left[\begin{array}{l} \text{\text{DIM_score}} = \frac{\text{\text{media codificada}}}{\text{\text{valor_máximo_posible}}} \times 100 \end{array} \right]$$

Por ejemplo, si GOV se calcula a partir de cinco preguntas codificadas de 0 a 4 y la media obtenida es 2,8:

$$\left[\begin{array}{l} \text{\text{GOV}} = \frac{2,8}{4} \times 100 = 70 \end{array} \right]$$

5.3. Composición del IGM

El IGM se obtiene como media ponderada de las dimensiones:

$$\left[\begin{array}{l} \text{\text{IGM}} = w_{\text{\text{GOV}}} \cdot \text{\text{GOV}} + w_{\text{\text{RISK}}} \cdot \text{\text{RISK}} + w_{\text{\text{REQ}}} \cdot \text{\text{REQ}} + w_{\text{\text{MET}}} \cdot \text{\text{MET}} \\ + w_{\text{\text{CAP}}} \cdot \text{\text{CAP}} \end{array} \right]$$

Con pesos por defecto:

- ($w_{\text{\text{GOV}}} = 0,2$)
- ($w_{\text{\text{RISK}}} = 0,25$)
- ($w_{\text{\text{REQ}}} = 0,25$)
- ($w_{\text{\text{MET}}} = 0,15$)
- ($w_{\text{\text{CAP}}} = 0,15$)

Estos pesos reflejan una ligera preferencia por la existencia de una base sólida de riesgos y requisitos, sin menospreciar la gobernanza ni las capacidades.

El resultado se redondea a un decimal y se puede clasificar en niveles:

- 0–19: Madurez muy baja (procesos incipientes o inexistentes)
- 20–39: Madurez baja (prácticas aisladas, sin sistematización)
- 40–59: Madurez media (bases razonables, pero inconsistentes)
- 60–79: Madurez alta (proceso sólido con áreas de mejora)
- 80–100: Madurez muy alta (referente en su sector, con capacidad de mentorear a otros)

6. Medición del ROI en requisitos de seguridad

Calcular el ROI exacto de la ingeniería de requisitos de seguridad es una empresa audaz. Aun así, conviene estimular el ejercicio intelectual. Una aproximación práctica:

6.1. Costes a considerar

- Horas dedicadas a la definición, revisión y mantenimiento de requisitos de seguridad (personal interno y externo).
- Costes de herramientas específicas (ALM, gestión de requisitos, etc.) imputables a este uso.
- Costes de formación en metodologías de requisitos de seguridad.

6.2. Beneficios estimables

- Incidentes evitados o mitigados (en número y severidad), comparando con períodos previos o escenarios de referencia.
- Reducción de retrabajo en fases de desarrollo y pruebas (número de cambios tardíos, defectos de seguridad detectados en producción).
- Mejora de tiempos y resultados en auditorías y certificaciones.
- Mejora de la continuidad de negocio (reducción de tiempos de interrupción, SLAs mejor cumplidos, etc.).

El ROI puede expresarse en términos clásicos:

$$\left[\text{ROI} = \frac{\text{Beneficios estimados} - \text{Costes}}{\text{Costes}} \right]$$

Lógicamente, buena parte de los beneficios será estimada. Lo importante no es la precisión absoluta, sino la disciplina de cuantificar hipótesis y comprobar tendencias.

7. Uso de la encuesta a nivel nacional y sectorial

Aplicada de forma consistente en múltiples organizaciones, la encuesta permite:

- Estimar la distribución de madurez por sector, tamaño y tipo de organización.
- Correlacionar IGM con indicadores de incidentes y vulnerabilidades reportados por organismos como INCIBE o ENISA.
- Alimentar análisis comparativos internacionales, siempre con prudencia metodológica.

Se sugiere repetir la encuesta de forma anual o bianual, manteniendo el núcleo de preguntas para poder observar tendencias, e introduciendo módulos específicos según necesidades (por ejemplo, algoritmos post-cuánticos, IA generativa, etc.).

8. Lectura crítica y sesgos

Ningún cuestionario se salva de los sesgos:

- Sesgo de deseabilidad social (tendencia a responder lo que “debería” ser).
- Sesgo de conocimiento (respuestas “no lo sé” encubiertas como “sí, pero...”).
- Sesgo de responsabilidad (minimización de problemas en áreas cercanas al rol del respondente).

Por ello, es recomendable:

- Acompañar la encuesta con entrevistas cualitativas a una muestra de organizaciones.
- Contrastar las respuestas con evidencias objetivas (políticas, informes, métricas de incidentes).
- Mantener el anonimato y la confidencialidad en análisis agregados, para favorecer la sinceridad.

9. Espíritu de uso

Si tras aplicar esta encuesta descubre que su organización se ubica en el “lejano oeste digital”, no se desespere: está en buena compañía. Lo relevante es disponer de un punto de partida honesto y de una brújula para el progreso.

La metodología SQUARE nos recuerda que la seguridad no se improvisa al final, sino que se negocia, define y escribe al principio. Esta encuesta simplemente se empeña en preguntar si lo estamos haciendo... o seguimos escribiendo la palabra “seguro” con lápiz blando.